

Clickjacking

(UI Redressing);

Görünmez Tıklama Saldırıları ve Savunma Yöntemleri

Eray Büyükşerbetci

1030521245

Emir Tekinşen

1030521269

Doç. Dr. NESİBE YALÇIN

Yazılım Güvenliği

Clickjacking Nedir?

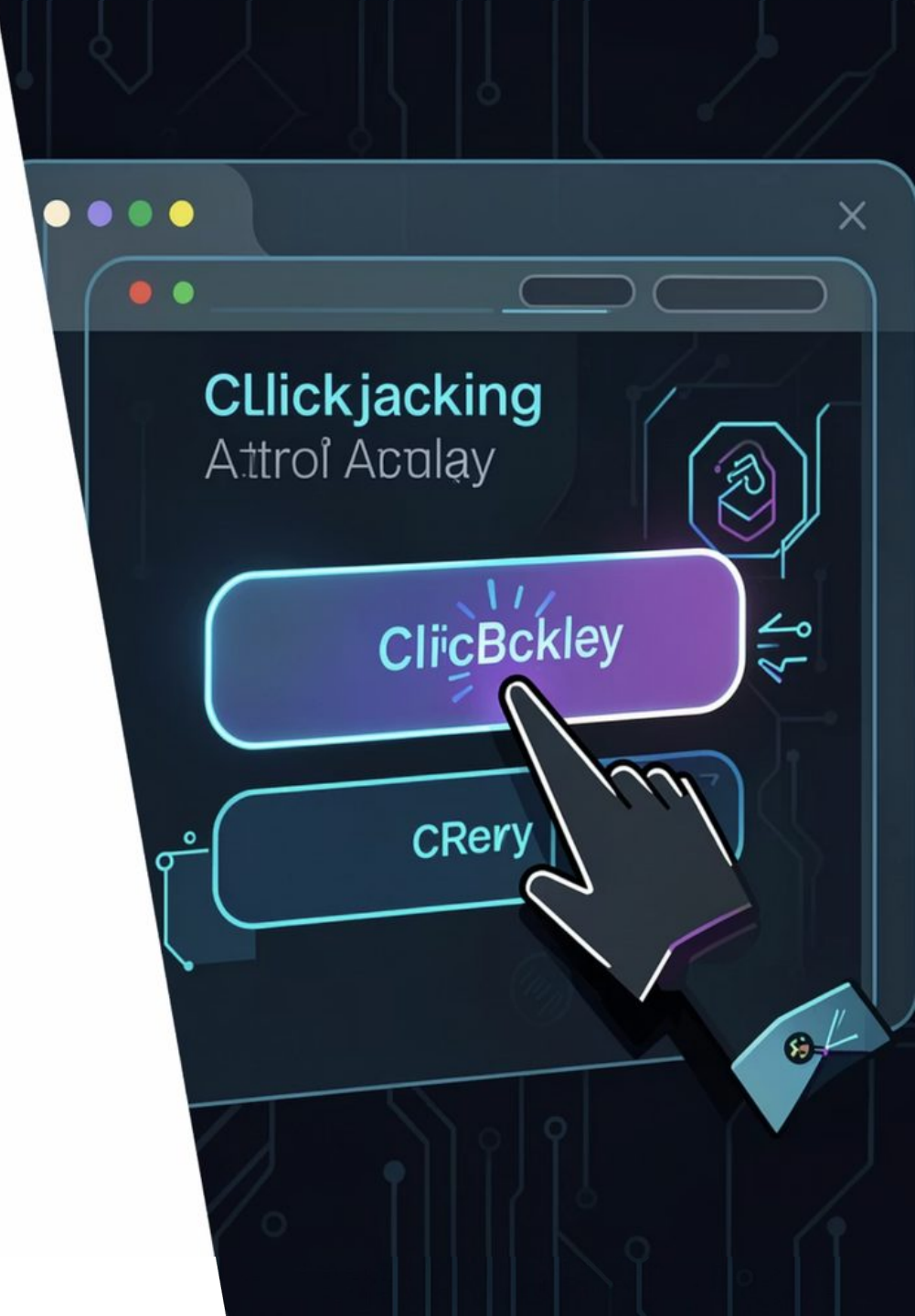
Kullanıcının Gördüğü

- Kampanyaya Katıl
- Hediye Al
- Oyuna Başla

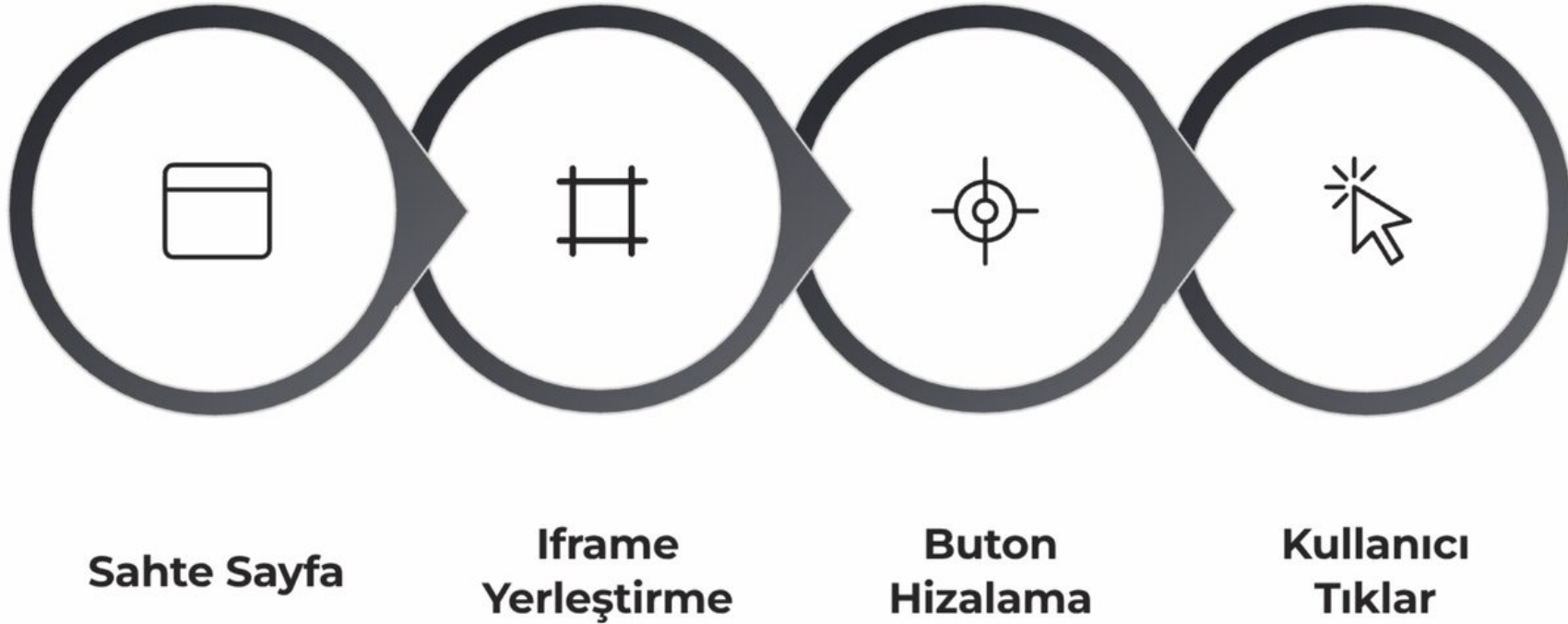
Gerçekte Olan

- Para transferi
- Yetki verme
- Hesap ayarlarını değiştirme

Temel Mantık: Kullanıcının gördüğü öğe ile tıkladığı öğe **farklıdır.**



Clickjacking Nasıl Çalışır?



Bu dört adımlı süreç, saldırganın kullanıcıyı fark ettirmeden hedef sisteme istenmeyen eylemler yaptırmasını mümkün kılar.

Kullanılan Teknikler



iframe

Başka bir web sayfasını mevcut sayfa içerisine gömer.



opacity

Öğeyi görünmez hale getirir.



z-index

Katman sırasını belirler.



position: absolute

Öğeleri aynı koordinata hizalar.

Amaç: Kullanıcının fark etmeden gerçek hedefe tıklamasını sağlamak.

Gerçek Hayat Senaryoları

Sosyal Medya

- Beğeni yaptıırma
- Takip ettirme
- Uygulama yetkisi verme

Bankacılık

- Para transferi
- İşlem onayı

Kurumsal Sistemler

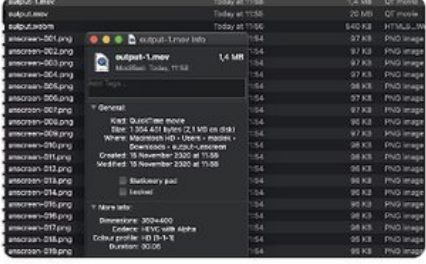
- Kullanıcı silme
- Yetki yükseltme

Bulut Sistemleri

- API erişimi verme
- Güvenlik ayarlarını deęiştirme



Clickjacking Türleri



Classic Clickjacking

Görünmez iframe kullanılır. En yaygın ve temel saldırı biçimidir.



Cursorjacking

Fare imlecinin konumu değiştirilir, kullanıcı farklı bir yere tıkladığını zanneder.



Likejacking

Sosyal medya etkileşimleri manipüle edilir.



Filejacking

Dosya yükleme alanları hedef alınır.

Clickjacking ve CSRF

Clickjacking

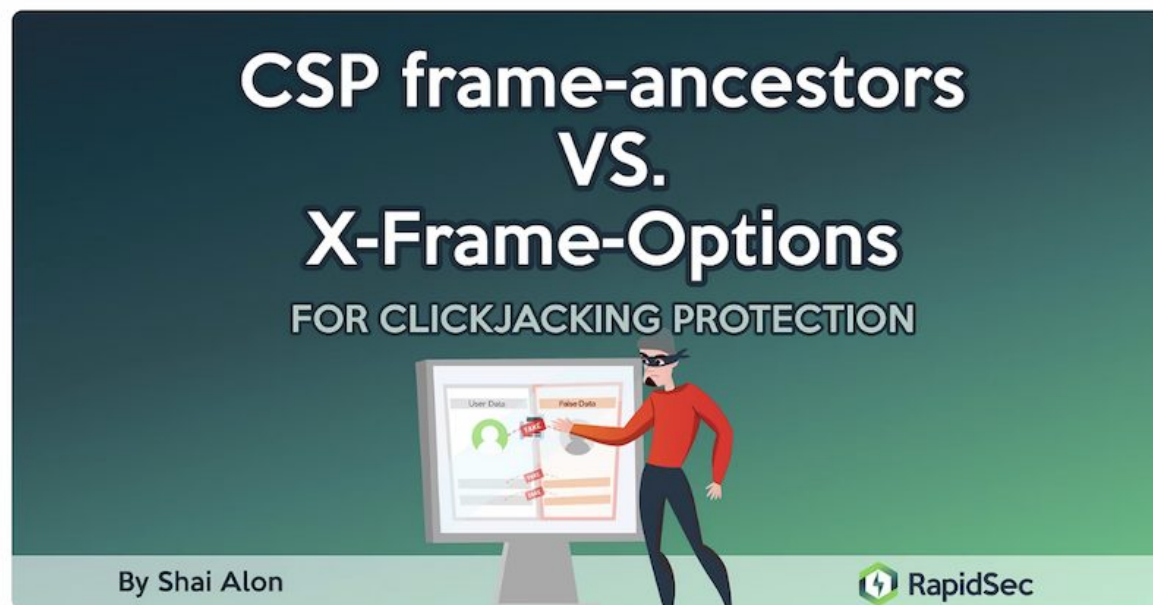
- Kullanıcı tıklaması gerekir
- Arayüz manipülasyonu kullanır
- Görsel aldatmaya dayanır

CSRF

- Sahte HTTP isteği kullanır
- Kullanıcı tıklaması gerekmeyebilir
- Sunucu tarafını hedefler

CSRF koruması tek başına Clickjacking'i engellemez. Her iki saldırı türüne karşı ayrı önlemler alınmalıdır.

X-Frame-Options



DENY

Sayfa hiçbir iframe içerisinde açılmaz.
En kısıtlayıcı ve güvenli seçenektir.

X-Frame-Options: DENY

SAMEORIGIN

Sadece aynı alan adı tarafından
görüntülenebilir. Kendi uygulamanız
içinde iframe kullanımına izin verir.

X-Frame-Options: SAMEORIGIN

Content Security Policy (CSP)

frame-ancestors Direktifi

Sayfanın hangi kaynaklar tarafından iframe içine alınabileceğini belirler. X-Frame-Options'a göre daha modern ve esnek bir koruma mekanizmasıdır.

```
Content-Security-Policy: frame-ancestors 'none';
```

Bu direktif ile sayfanın hiçbir kaynak tarafından iframe içine alınması engellenir.

Modern Koruma

Güncel tarayıcı standartlarına uygundur.

Esnek Yapı

Belirli kaynaklara izin verilebilir.

Güçlü Savunma

Kapsamlı saldırı önleme sağlar.

Geniş Tarayıcı Desteği

Tüm modern tarayıcılarda çalışır.

Sonuç

Clickjacking

Kullanıcıyı kandırmaya dayalı bir web saldırısıdır.

Risk

Kullanıcının mevcut oturum yetkileri kullanılarak yetkisiz işlemler gerçekleştirilebilir.

Savunma Yöntemleri

- X-Frame-Options
- Content Security Policy (CSP)
- Çok Faktörlü Kimlik Doğrulama (MFA)
- CSRF Koruması

Clickjacking'e karşı en etkili yaklaşım, teknik güvenlik önlemleri ile kullanıcı farkındalığının birlikte kullanıldığı katmanlı güvenlik modelidir.



Kaynaklar & Teşekkürler

Kaynaklar

<https://portswigger.net/web-security/clickjacking>

<https://www.imperva.com/learn/application-security/clickjacking/>

<https://owasp.org/www-community/attacks/Clickjacking>

<https://hacktricks.wiki/tr/pentesting-web/clickjacking.html>

<https://www.youtube.com/watch?v=UWgSh-5eNxw>

<https://auth0.com/blog/preventing-clickjacking-attacks/>

Bu sunumu dinlediğiniz ve zaman ayırdığınız için teşekkür ederiz. Değerli katkıları için Doç. Dr. Nesibe Yalçın'a şükranlarımızı sunarız.